

ProcuraFlow System Integrity & Audit Readiness Report

Audit date: 11 August 2026

Application: ProcuraFlow Professional Edition

Review type: Technical, database, security, workflow, reporting, UI/UX, and audit-readiness assessment

Executive Summary

ProcuraFlow has a substantial integrated control foundation: 63 business/system tables, enforced SQLite foreign keys, transactional stock functions, FIFO layers, a permanent stock ledger, approval history, audit logs, role and individual permissions, assigned-warehouse controls, professional documents, and operational reporting. The production frontend and backend compile successfully. The database integrity check and all 48 existing deterministic audit checks pass with zero findings.

This review corrected three verified High-severity access/export weaknesses and added four administrator control reports. It did not reset data, rewrite historical transactions, remove approvals, or silently reconcile unexplained inventory differences.

The overall rating is WARNING – controlled operation is possible, but open High governance items require resolution before an unqualified audit-ready rating. Specifically, legacy ledger totals differ from current stock for 52 item/warehouse combinations even though stock and FIFO agree, seven non-management users have potentially conflicting permission combinations, and warehouse scoping is not yet uniform across all aggregate report endpoints.

Scope and Method

The review covered backend schema and runtime migrations, 63 tables, keys and indexes, API routes, authentication, role/individual permissions, warehouse access utilities, attachments, procurement and warehouse workflows, inventory ledger/FIFO controls, invoice reconciliation, reports/exports, dashboard/help content, backup/restore code, and production builds.

Evidence included:

- ? SQLite `integrity\_check` and `foreign\_key\_check`.
- ? The application's 48-control `npm run audit:db` suite.
- ? Schema inventory of primary keys, foreign keys, indexes, and row counts.
- ? Static review of API authentication, authorization, transactions, numbering, error handling, uploads, and exports.
- ? Backend and frontend TypeScript production builds.
- ? Authenticated API smoke tests of all four new control reports.
- ? Filesystem validation of all five registered attachments.

Full destructive workflow/concurrency testing was not performed against the live historical database. No PASS below implies tests that were not actually executed.

System Health Dashboard

Area	Result	Evidence / explanation
Database integrity	PASS	SQLite integrity is `ok`; zero foreign-key violations
Current stock vs FIFO	PASS	Zero stock/FIFO mismatches and zero negative balances/layers

Document numbering | PASS | Server-side, fiscal-year-scoped counters; no duplicate PR, PO, or GRN numbers

Role security | WARNING | Backend enforcement exists; 7 non-management SoD conflicts need review

Warehouse transaction restrictions | PASS | Assigned-warehouse checks exist on stock operations; GRN detail gap corrected

Warehouse report restrictions | FAIL | Some aggregate warehouse reports remain role-protected but not assignment-scoped

Procurement workflow | WARNING | Structural/data checks pass; full end-to-end mutation regression test not executed

Three-way match data controls | PASS | No submitted source mismatch, unresolved reconciliation, or missing evidence findings

Approval controls | PASS | Approval authority, self-approval controls, limits, and history are implemented

Audit trail | PASS | 170 audit rows plus login/activity/approval history; ordinary routes do not edit audit history

Attachment integrity | PASS | Five attachment records; zero missing files; authorization strengthened

Duplicate document/master codes | PASS | No duplicate active item/supplier/employee codes or PR/PO/GRN numbers

Duplicate descriptive masters | PASS | New report returned zero current exact-name duplicate groups

Report export security | PASS | Formula-leading values neutralized and HTML encoded; frontend build passes

Report accuracy | WARNING | Integrity/control reports tested; every business total/filter was not independently recalculated

Backup validation | WARNING | Backup/restore staging exists; a full restore drill was not performed in this review

UI consistency | WARNING | Shared components and build pass; exhaustive visual/browser matrix was not executed

Performance | WARNING | Index inventory reviewed; no production load or query-plan benchmark performed

Database Health

The database contains 63 application tables and 26 explicit indexes. Every table has a declared primary key, including the composite numbering counter key. Foreign keys are enabled. The live database contains 90 stock-ledger entries, 170 audit entries, and five registered attachments.

All existing deterministic checks passed, including negative stock, negative FIFO, stock/FIFO agreement, invalid GRN splits, GRN/PO cost mismatch, issue/FIFO usage, over-returns, document duplicates, invalid quantities/prices, PO totals, PO closure, employee/login linkage, warehouse assignments, currency conversion, invoice reconciliation/evidence, calendar controls, helper access, city/country relationships, and duplicate-review integrity.

No tables or historical business records were removed because unused-table proof and retention approval were not established.

Security and Access Controls

Positive controls include bcrypt password hashing, eight-hour JWT expiry, production JWT-secret enforcement, account status/expiry checks on every authenticated request, five-attempt/15-minute login throttling, password expiry and forced change, CORS allowlisting, security headers, backend role/individual permission checks, protected error messages in production, prepared SQL statements, MIME/size-restricted attachments, and assigned-warehouse utilities.

Corrected High findings:

1. Attachment downloads, lists, and uploads now validate access to the parent document and assigned GRN warehouse.
2. Direct GRN detail access now validates the warehouse employee's active assignment.
3. Excel-compatible report exports now encode HTML and neutralize formula-leading content.

Open High findings:

- ? Seven non-management accounts have permission combinations flagged by the new SoD report. These require documented management decisions and, where appropriate, reduced permissions or independent review.
- ? Several aggregate inventory/warehouse report queries are not yet consistently filtered to assigned warehouses. Until remediated, restrict report permission assignment to personnel authorized for the report's full scope.

Procurement, Warehouse, and Financial Controls

PR, RFQ, quotation, PO, GRN, invoice, and approval relationships are represented in the schema. PO/PR allocation tables retain partial-conversion traceability. GRN posting validates approved PO status, PO items, positive quantities, accepted/rejected splits, approved costs, assigned warehouse and Bin, and uses a database transaction for posting. Material issues, returns, transfers, adjustments, and cycle counts use controlled routes and approval logic.

Invoice controls compare PO, accepted GRN, and invoice values, preserve original values, classify reconciliation, require reason/evidence for accepted differences, and block Finance submission on unresolved source mismatch. Current audit data shows no submitted exceptions.

Full PR-to-Finance, concurrent final-stock issue, concurrent receipt, cancellation, and closed-fiscal-year mutation scenarios remain a required automated test backlog.

Inventory Integrity

Current inventory_stock agrees with FIFO layers at the item/warehouse/location level, with no negative stock. This supports current on-hand integrity.

The new Inventory Integrity report also compares permanent-ledger totals. It reports 52 WARNING rows where the ledger total differs from current stock, while stock and FIFO still agree. This likely reflects opening/historical data created before complete ledger coverage, but that explanation is an inference and must be evidenced. ProcuraFlow correctly does not auto-correct these rows. Investigation should document the opening source, expected ledger opening entry, value basis, and approved reconciliation decision.

Audit Trail and Documents

The system records master/transaction changes, approvals, authentication history, user activity, calendar changes, backup actions, and key settings operations. Posted inventory movements are represented in the permanent ledger. Professional PR, PO, GRN, approval, Finance, report, and calendar outputs use centralized branding components and generated-by/date metadata.

Attachment records store type, parent ID, original/stored name, MIME type, size, uploader, and timestamp. All five live attachment files exist. Parent-level access is now enforced.

Reports and Control Monitoring

Four new reports are available under Reports > System Administration for Supply Chain Managers with report.system permission:

- ? System Integrity Check
- ? Inventory Integrity
- ? Duplicate Master Data
- ? Segregation of Duties Conflicts

Existing report exports apply selected client filters. Exported spreadsheet values are now protected against formula and HTML injection. A future release should move filters into report APIs for large datasets and apply assigned-warehouse predicates centrally.

Before and After Results

Severity | Before review | Corrected | Remaining

HIGH | 6 verified | 3 | 3 control/governance items

MEDIUM | 5 verified | 4 | 1 automated-test gap

LOW | Not exhaustively counted | 0 | Build/deprecation and visual-review backlog

High remaining items comprise legacy ledger reconciliation, non-management SoD conflicts, and incomplete assigned-warehouse scoping in aggregate reports. Counts describe verified issue categories, not individual affected rows.

Testing Performed

- ? Backend production build: PASS.
- ? Frontend production build: PASS.
- ? SQLite integrity: PASS.
- ? 48 database/business integrity controls: PASS with zero findings.
- ? New System Integrity API: HTTP 200, seven controls returned, all PASS.
- ? New Inventory Integrity API: HTTP 200, 80 rows (28 PASS, 52 WARNING).
- ? New Duplicate Master Data API: HTTP 200, zero current exact-name groups.
- ? New SoD API: HTTP 200, 11 review rows (7 HIGH, 4 authorized-management review).
- ? Attachment filesystem validation: five registered, zero missing.
- ? Backend health endpoint after restart: PASS.

Remaining Recommendations

1. **HIGH:** Add assigned-warehouse predicates to every inventory, warehouse, employee-consumption, and tool report API; add negative authorization tests.
2. **HIGH:** Review and sign off all seven non-management SoD conflicts; remove unnecessary task permissions.
3. **HIGH:** Reconcile the 52 legacy ledger warnings through controlled opening-ledger evidence; do not modify history without approved deterministic methodology.
4. Add automated API/integration tests using an isolated database for PR !' PO !' GRN !' I issue/return/transfer/adjustment/cycle count, permissions, fiscal-year closure, attachments, and concurrency.
5. Add a tested backup package containing database, uploads, and configuration manifest, plus a recorded restore-test history.
6. Add explicit accounting-period Open/Soft Closed/Closed controls if period posting is required beyond fiscal-year labeling.
7. Add controlled document revision/amendment records before allowing changes to approved documents.
8. Perform an accessibility, responsive-width, and browser visual-regression pass.
9. Benchmark high-volume report queries and add indexes only from measured query plans.

Final Risk Rating

WARNING / MODERATE-HIGH residual control risk. Current database and stock/FIFO integrity are strong, and the three verified High implementation weaknesses were corrected. An unqualified audit-ready PASS is not appropriate until warehouse report scoping, SoD review, legacy ledger reconciliation, restore testing, and isolated workflow/concurrency testing are completed.